

GDPR & Data Protection Policy

How DoseRX processes operational data for Irish EMS — with no patient names, hashed CAD references, and encryption in transit and at rest.

Version 1.0

6 August 2026

Local policy document

This policy explains DoseRX's approach to the EU General Data Protection Regulation (GDPR) and the Irish Data Protection Act 2018 when the product is used by a client for pre-hospital medicines and controlled-drug operational control.

Core principle: DoseRX does *not* store patient names, dates of birth, addresses, or clinical narratives. The only incident-linked reference intended for the system is a **CAD last-4 digit reference**, which is **not stored as plain digits**. DoseRX stores a **cryptographic hash** derived from CAD last-4 + date + a salt held by the data controller. Data is protected with **encryption in transit** and **encryption at rest** on approved cloud services.

1. Roles & responsibilities

Role	Who	Responsibility
Data controller	Client	Decides why/how operational data is processed; holds the CAD hashing salt ; sets retention; signs DPIA
Data processor	DoseRX supplier	Processes data only on controller instructions; stores hashes not CAD digits; secures hosting; assists with rights & breaches
Sub-processors	Cloud host / database (e.g. EU-region SaaS)	Infrastructure encryption, availability; bound by DPA / SCCs as applicable

2. What we collect — and what we never collect

We do process (operational)

Staff name / ID / grade; bag & medication stock events; dose, route, indication; witnesses; lot/expiry; seals; timestamps; optional location or evidence photos if enabled by the controller.

We do not process (patient identity)

No patient name, PPSN, phone, address, photograph of the patient, free-text clinical story, or full CAD/incident number.

CAD last-4: Even four digits can be personal data when combined with date, crew, and medication. DoseRX therefore treats the CAD reference as **protected operational data** and applies hashing + encryption — not “anonymous by default.”

3. CAD reference: hash of CAD + date + salt

To avoid storing recoverable CAD digits on DoseRX systems, the product design uses a **one-way hash**:

```
Controller (client)
└─ Holds secret SALT (never sent to DoseRX in clear for storage)

Practitioner enters CAD last-4 digits in the app
└─ App / secure edge computes:
    HASH = SHA-256( CAD_LAST4 + "|" + INCIDENT_DATE + "|" + SALT )

DoseRX stores / syncs only:
└─ HASH (+ metadata: bag, drug, staff, time)
└─ NOT the raw CAD digits

Cloud transport & storage:
└─ TLS (encryption in transit)
└─ Provider encryption at rest (disk/volume encryption)
```

3.1 Why this model

- **Minimisation** — DoseRX cannot reverse the hash to reveal CAD digits without the controller’s salt.
- **Controller control** — Only the controller (or a system they authorise) can correlate a hash back to a CAD for investigation, using the salt and original last-4 if they still hold it in their own PCR/CAD systems.
- **Purpose limitation** — DoseRX retains enough to support medicines/CD audit without building a patient-identifiable record.

3.2 What DoseRX staff can see

Support and engineering accessing production data (under break-glass rules) would see a **hash string**, not “4821” or any patient name. Correlation to a real CAD remains a **controller-side** activity.

4. Encryption in transit and at rest

Layer	Control	Purpose
In transit	HTTPS / TLS between browser and DoseRX / cloud APIs	Stops eavesdropping of hashed CAD refs and operational payloads on the network

At rest	Cloud database & object storage encryption (provider-managed keys; EU region preferred)	Protects stored hashes and operational records on disk
Application	Store hash only — never persist plain CAD last-4 in database fields	Limits impact if a datastore is compromised
Exports / PDFs	Default exports show hash or omit CAD; elevated roles only if controller configures	Purpose limitation for inspection packs

Cloud services used for hosting and database sync are engaged as **sub-processors** under a Data Processing Agreement. Production deployments should use **EU data residency** (e.g. Ireland / Frankfurt) unless the controller documents otherwise.

5. Lawful basis (summary for DPIA)

- **Operational staff data** — typically legitimate interests of the client / public task for running the client's service (controller to confirm).
- **Medicines & CD governance logs** — public task / legal obligation related to controlled drugs and clinical governance (controller to confirm).
- **Any health-adjacent linkage** (medication given against an incident token) — Article 9 condition as determined by the controller's DPO (e.g. health care / public interest).

Consent is *not* the primary basis for staff operational logging in this context.

6. Data subject rights

Staff may exercise GDPR rights (access, rectification, restriction, etc.) via the **controller** (client channels). DoseRX as processor assists within DPA timescales. Because patient names are not stored, DoseRX is not a patient EHR access channel.

7. Retention & deletion

- Retention periods are set by the **controller's** records policy.
- When retention expires, DoseRX deletes or anonymises operational rows including CAD hashes from live systems, and follows backup expiry rules.
- Training / sandbox modes must not use real CAD values.

8. Security & breach

- Access control by role (practitioner vs management).
- Production target: unique accounts and multi-factor authentication.
- Personal data breaches involving DoseRX processing are notified to the controller without undue delay so the controller can meet the 72-hour regulatory clock where applicable.

9. International transfers

Prefer **no transfers outside the EEA**. If a sub-processor processes outside the EEA, appropriate safeguards (e.g. Standard Contractual Clauses) must be recorded in the sub-processor schedule.

10. Policy statements (plain language)

1. No information relating to the **personal identity of patients** is stored in DoseRX.
2. The only incident reference designed into the product is a **CAD last-4 digit** style reference for operational audit.
3. That reference is converted to a **hash of CAD + date + salt**; the **salt is held only by the controller**; DoseRX stores the **hash, not the digits**.
4. All such data is protected using **encryption in transit (TLS)** and **encryption at rest** on cloud services used to host and sync the application.
5. Cloud processing is performed under contractual processor terms and documented sub-processors.

IMPORTANT This document is a supplier policy / design statement for DoseRX. It does not replace a controller DPIA, client Data Processing Agreement, or legal advice. Implementation of hashing must match the technical controls described before production go-live with live CAD entry.